UNIVERSITY OF INSUBRIA

Department of Theoretical and Applied Sciences – DiSTA
Master of Science in Computer Science

DATA SECURITY AND PRIVACY

Project Work:
Pharmaceutical Clinical Trial Database Management System

Author:
Roberto Vicario

Student ID:
744072

Academic Year 2025-2026

Contents

1 Task 1

1.1 Scenario

The proposed scenario is a **Pharmaceutical Clinical Trial Management System**. A pharmaceutical company uses the database to manage clinical studies, trial sites, staff assignments, pseudonymized participants, trial documents and adverse event reports.

The scenario is intentionally suitable for the following access control models:

- **DAC**: object privileges can distinguish who can read or update operational tables such as documents, assignments and safety events.
- **RBAC**: users naturally map to roles such as principal investigator, study coordinator, monitor, data manager, regulatory officer, sponsor representative and quality auditor.
- **VPD**: row-level predicates can restrict access by assigned study, assigned site, staff region or sponsor relationship.
- **OLS**: clinical and personal data can be classified with labels such as `PUBLIC`, `INTERNAL`, `CONFIDENTIAL` and `RESTRICTED`.

1.2 Users

The setup script creates one schema owner and seven application users.

User	Intended role
`CT_OWNER`	schema owner
`CT_PI_ROSSI`	principal investigator
`CT_COORD_BIANCHI`	study coordinator
`CT_CRA_VERDI`	clinical research associate / monitor
`CT_DATA_NERI`	data manager
`CT_REG_BLU`	regulatory officer
`CT_AUDITOR_GIALLI`	quality auditor
`CT_SPONSOR_LILA`	sponsor representative

The users are created in `app/1/00_create_users.sql`. The schema and sample data are created in `app/1/01_create_schema.sql`.

1.3 Schema

1.3.1 STUDIES

Stores general information about clinical studies.

Attribute	Description
STUDY_ID	primary key
CODE	public study code
TITLE	study title
THERAPEUTIC_AREA	medical area
PHASE	trial phase (I, II, III, IV)
SPONSOR	sponsoring organization
PRINCIPAL_INV_ID	responsible principal investigator
BUDGET_EUR	study budget
STATUS	operational status
SENSITIVITY_LABEL	future OLS classification

1.3.2 SITES

Stores clinical sites involved in the studies.

Attribute	Description
SITE_ID	primary key
SITE_NAME	clinical site name
COUNTRY	country
REGION	geographical region (EU, US, APAC)
LEAD_INVESTIGATOR	site investigator
CONTACT_EMAIL	site contact

1.3.3 STAFF_MEMBERS

Maps database users to business roles, regions and clearance levels.

Attribute	Description
STAFF_ID	primary key
USERNAME	Oracle user name
FULL_NAME	staff member name
JOB_ROLE	business role
ORGANIZATION	employer or unit
REGION	operational region
CLEARANCE	future OLS clearance

1.3.4 STUDY_ASSIGNMENTS

Associates staff members with studies and, when relevant, with a specific site.

Attribute	Description
ASSIGNMENT_ID	primary key
STUDY_ID	assigned study
STAFF_ID	assigned staff member
SITE_ID	assigned site, nullable for global roles
ASSIGNMENT_ROLE	role in the study
START_DATE	assignment start
END_DATE	assignment end

1.3.5 PARTICIPANTS

Stores pseudonymized participant records. Direct identifiers are excluded.

Attribute	Description
`PARTICIPANT_ID`	primary key
`STUDY_ID`	related study
`SITE_ID`	enrolling site
`SUBJECT_CODE`	pseudonymous participant code
`AGE_BAND`	age interval
`SEX`	sex value (`F`, `M`, `X`)
`ENROLLMENT_DATE`	enrollment date
`CONSENT_STATUS`	consent status
`RANDOMIZATION_GROUP`	treatment or observation group
`PERSONAL_DATA_LABEL`	future OLS classification

1.3.6 `TRIAL_DOCUMENTS`

Stores trial documents and their sensitivity level.

Attribute	Description
`DOCUMENT_ID`	primary key
`STUDY_ID`	related study
`SITE_ID`	related site, nullable for study-level documents
`DOCUMENT_TYPE`	protocol, consent form, safety report, etc.
`TITLE`	document title
`VERSION_NO`	document version
`OWNER_STAFF_ID`	staff member responsible for the document
`APPROVAL_STATUS`	document workflow state
`CLASSIFICATION`	future OLS classification
`STORAGE_URI`	logical document location

1.3.7 ADVERSE_EVENTS

Stores safety events reported during clinical studies.

Attribute	Description
EVENT_ID	primary key
PARTICIPANT_ID	related participant
STUDY_ID	related study
REPORTED_BY	reporting staff member
EVENT_DATE	event date
SEVERITY	safety severity
EXPECTEDNESS	expected or unexpected event
NARRATIVE	clinical narrative
SAFETY_LABEL	future OLS classification

1.4 Initial Data

The script inserts:

- 3 studies;
- 3 clinical sites;
- 7 staff members;
- 7 study assignments;
- 4 pseudonymized participants;
- 6 trial documents;
- 3 adverse event reports.

This data is enough to test future policies based on object privileges, user roles, assigned studies, assigned sites, geographical regions and information classification.

1.5 Execution

Run the scripts in this order:

```
-- As ADMIN
```

```
@app/1/00_create_users.sql

-- As CT_OWNER
@app/1/01_create_schema.sql
```

2 Task 2

2.1 Goal

This task defines discretionary access control policies for the Clinical Trial Management schema created in Task 1. The implementation uses Oracle DAC mechanisms: views and object privileges granted to specific users.

The SQL code is in:

- `app/2/01_dac_policies.sql`;
- `app/2/02_check_dac_privileges.sql`.

2.2 DAC Policies

2.2.1 P1. General study information

All application users can read general study information, but not the study budget and not the principal investigator identifier.

Implementation:

- create one projection view over `STUDIES`;
- exclude `BUDGET_EUR` and `PRINCIPAL_INV_ID`;
- grant `SELECT` on the view to all application users.

Cost:

- views: 1;
- authorizations: number of application users, here 7;
- total implemented cost: `1 view + 7 grants`.

Implemented by `V_STUDY_PUBLIC_INFO`.

2.2.2 P2. Principal investigator access to assigned studies

The principal investigator can read complete information, including budget, for studies where they are assigned as `PI`.

Implementation:

- create one view for `CT_PI_ROSSI`;
- join `STUDIES` with `STUDY_ASSIGNMENTS`;
- filter assignments where `STAFF_ID = 1` and `ASSIGNMENT_ROLE = 'PI'`;
- grant `SELECT` only to `CT_PI_ROSSI`.

Cost:

- views: number of principal investigators, here 1;
- authorizations: number of principal investigators, here 1;
- total implemented cost: `1 view + 1 grant`.

Implemented by `V_PI_ROSSI_STUDIES`.

2.2.3 P3. Study coordinator access to local participants

A study coordinator can read pseudonymized participant records only for the study and site where they are assigned. The personal data classification column is not exposed.

Implementation:

- create one view for `CT_COORD_BIANCHI`;
- join `PARTICIPANTS` with `STUDY_ASSIGNMENTS`;
- filter by coordinator assignment on the same study and site;
- grant `SELECT` only to `CT_COORD_BIANCHI`.

Cost:

- views: number of coordinator-site assignments, here 1;
- authorizations: number of coordinator-site assignments, here 1;
- total implemented cost: `1 view + 1 grant`.

Implemented by `V_COORD_BIANCHI_PARTICIPANTS`.

2.2.4 P4. Monitor access to assigned monitoring documents

A clinical research associate acting as monitor can read monitoring reports only for the assigned study site.

Implementation:

- create one view for `CT_CRA_VERDI`;
- join `TRIAL_DOCUMENTS` with `STUDY_ASSIGNMENTS`;
- filter by monitor assignment and `DOCUMENT_TYPE = 'MONITORING_REPORT'`;
- grant `SELECT` only to `CT_CRA_VERDI`.

Cost:

- views: number of monitor-site assignments, here 1;
- authorizations: number of monitor-site assignments, here 1;
- total implemented cost: `1 view + 1 grant`.

Implemented by `V_CRA_VERDI_MONITORING_DOCS`.

2.2.5 P5. Regulatory officer access to regulatory material

A regulatory officer can read regulatory submissions and related protocol or consent documents for assigned studies.

Implementation:

- create one view for `CT_REG_BLU`;
- join `TRIAL_DOCUMENTS` with `STUDY_ASSIGNMENTS`;
- filter by regulatory reviewer assignment;
- expose only `REGULATORY_SUBMISSION`, `PROTOCOL`, and `INFORMED_CONSENT` documents;
- grant `SELECT` only to `CT_REG_BLU`.

Cost:

- views: number of regulatory reviewer assignments, here 1;
- authorizations: number of regulatory reviewer assignments, here 1;
- total implemented cost: `1 view + 1 grant`.

Implemented by `V_REG_BLU_SUBMISSIONS`.

2.2.6 P6. Sponsor access to non-financial documents

A sponsor representative can read non-financial documents for assigned studies, but cannot read financial contracts and cannot read participant or adverse event tables.

Implementation:

- create one view for `CT_SPONSOR_LILA`;
- join `TRIAL_DOCUMENTS` with `STUDY_ASSIGNMENTS`;
- filter sponsor assignments;
- exclude `FINANCIAL_CONTRACT`;
- grant `SELECT` only to `CT_SPONSOR_LILA`.

Cost:

- views: number of sponsor viewer assignments, here 1;
- authorizations: number of sponsor viewer assignments, here 1;
- total implemented cost: `1 view + 1 grant`.

Implemented by `V_SPONSOR_LILA_NON_FINANCIAL_DOCS`.

2.3 Additional Implemented Policy

The SQL also implements an extra quality auditor policy:

- `CT_AUDITOR_GIALLI` can read safety events for studies where they are assigned as `AUDITOR`;
- implemented by `V_AUDITOR_GIALLI_SAFETY_EVENTS`;
- cost: `1 view + 1 grant`.

This policy is not needed to reach the required number of high-level policies, but it gives a useful DAC baseline for later comparison with RBAC, VPD and OLS.

2.4 Global Cost Analysis

For the six required policies:

Policy	Views	Grants
P1	1	7

Policy	Views	Grants
P2	1	1
P3	1	1
P4	1	1
P5	1	1
P6	1	1
Total	**6**	**12**

Including the additional auditor policy, the implemented SQL creates:

- 7 views;
- 13 `SELECT` grants.

2.5 SQL Execution

Run the scripts after completing Task 1:

```
-- As CT_OWNER
@app/2/01_dac_policies.sql
@app/2/02_check_dac_privileges.sql
```

The inspection script queries `USER_TAB_PRIVS` and contains example `CONNECT` and `SELECT` commands for each application user.

3 Task 3

3.1 Goal

This task redesigns the access control policies from Task 2 using RBAC. The implementation defines roles, a role hierarchy, role-permission assignments and user-role assignments.

The SQL code is in:

- `app/3/00_create_roles_and_assignments.sql`;
- `app/3/01_grant_permissions_to_roles.sql`;
- `app/3/02_check_rbac_privileges.sql`.

Task 2 views are reused as protected objects. This is necessary because pure Oracle roles group privileges, but they do not by themselves express row-level conditions such as “only the assigned study” or “only the assigned site”.

3.2 Roles

Role	Meaning
CT_STUDY_READER	baseline role for general study information
CT_STUDY_OPERATOR	operational staff working on assigned study data
CT_STUDY_COORDINATOR	study coordinator
CT_STUDY_LEADER	principal investigator / study lead
CT_MONITOR	clinical research associate / monitor
CT_COMPLIANCE_READER	baseline compliance role
CT_REGULATORY_READER	regulatory reviewer
CT_AUDITOR	quality auditor
CT_SPONSOR_READER	sponsor representative

3.3 Role Hierarchy

The hierarchy contains eight relationships, which is more than the minimum required for a one-student group.

Senior role	Inherits from
CT_STUDY_OPERATOR	CT_STUDY_READER
CT_STUDY_COORDINATOR	CT_STUDY_OPERATOR
CT_STUDY_LEADER	CT_STUDY_OPERATOR
CT_MONITOR	CT_STUDY_OPERATOR
CT_COMPLIANCE_READER	CT_STUDY_READER
CT_REGULATORY_READER	CT_COMPLIANCE_READER
CT_AUDITOR	CT_COMPLIANCE_READER

Senior role	Inherits from
CT_SPONSOR_READER	CT_STUDY_READER

3.4 Role-Permission Assignment

Role	Permission
CT_STUDY_READER	SELECT on V_STUDY_PUBLIC_INFO
CT_STUDY_COORDINATOR	SELECT on V_COORD_BIANCHI_PARTICIPANTS
CT_STUDY_LEADER	SELECT on V_PI_ROSSI_STUDIES
CT_MONITOR	SELECT on V_CRA_VERDI_MONITORING_DOCS
CT_REGULATORY_READER	SELECT on V_REG_BLU_SUBMISSIONS
CT_AUDITOR	SELECT on V_AUDITOR_GIALLI_SAFETY_EVENTS
CT_SPONSOR_READER	SELECT on V_SPONSOR_LILA_NON_FINANCIAL_DOCS

3.5 User-Role Assignment

User	Assigned role
CT_PI_ROSSI	CT_STUDY_LEADER
CT_COORD_BIANCHI	CT_STUDY_COORDINATOR
CT_CRA_VERDI	CT_MONITOR
CT_DATA_NERI	CT_STUDY_OPERATOR
CT_REG_BLU	CT_REGULATORY_READER
CT_AUDITOR_GIALLI	CT_AUDITOR
CT_SPONSOR_LILA	CT_SPONSOR_READER

3.6 RBAC Policies

3.6.1 P1. General study information

All application users can read public study metadata through the inherited baseline role `CT_STUDY_READER`.

Cost:

- roles: 1 baseline role;
- permissions: 1;
- user-role assignments: 7, mostly through senior roles;
- hierarchy relationships used: all senior roles inherit directly or indirectly from `CT_STUDY_READER`.

3.6.2 P2. Principal investigator access

`CT_PI_ROSSI` receives `CT_STUDY_LEADER`, which inherits operational and general study permissions and adds complete access to the PI study view.

Cost:

- roles: 1 specific senior role;
- permissions: 1;
- user-role assignments: 1;
- hierarchy relationships: 2 inherited links to reach `CT_STUDY_READER`.

3.6.3 P3. Study coordinator access

`CT_COORD_BIANCHI` receives `CT_STUDY_COORDINATOR`, which can read the coordinator participant view and inherits operational and general study information.

Cost:

- roles: 1;
- permissions: 1;
- user-role assignments: 1;
- hierarchy relationships: 2 inherited links to reach `CT_STUDY_READER`.

3.6.4 P4. Monitor access

CT_CRA_VERDI receives CT_MONITOR, which inherits operational study access and adds access to monitoring documents.

Cost:

- roles: 1;
- permissions: 1;
- user-role assignments: 1;
- hierarchy relationships: 2 inherited links to reach CT_STUDY_READER.

3.6.5 P5. Regulatory officer access

CT_REG_BLU receives CT_REGULATORY_READER, which inherits compliance and general study access and adds access to regulatory material.

Cost:

- roles: 1;
- permissions: 1;
- user-role assignments: 1;
- hierarchy relationships: 2 inherited links to reach CT_STUDY_READER.

3.6.6 P6. Sponsor access

CT_SPONSOR_LILA receives CT_SPONSOR_READER, which inherits general study information and adds access to non-financial study documents.

Cost:

- roles: 1;
- permissions: 1;
- user-role assignments: 1;
- hierarchy relationships: 1.

3.6.7 Additional Auditor Policy

CT_AUDITOR_GIALLI receives CT_AUDITOR, which inherits compliance and general study access and adds access to safety events.

Cost:

- roles: 1;
- permissions: 1;
- user-role assignments: 1;
- hierarchy relationships: 2 inherited links to reach `CT_STUDY_READER`.

3.7 Global Cost Analysis

The implemented RBAC model has:

Item	Count
Roles	9
Role hierarchy relationships	8
Role-permission assignments	7
User-role assignments	7

Compared with the DAC implementation from Task 2, the protected views remain necessary for assignment-specific restrictions. However, privileges are now granted to roles instead of being granted directly to individual users. This reduces administrative cost when a new user joins an existing business function: the administrator assigns one role instead of repeating all object grants.

3.8 SQL Execution

Run the scripts in this order:

```
-- As ADMIN
@app/3/00_create_roles_and_assignments.sql

-- As CT_OWNER
@app/3/01_grant_permissions_to_roles.sql

-- As ADMIN, for inspection
@app/3/02_check_rbac_privileges.sql
```

The inspection script checks roles, hierarchy relationships, user-role assignments and role permissions. Application users can also check their active roles with:

```sql
SELECT * FROM user_role_privs ORDER BY granted_role;
SELECT * FROM session_roles ORDER BY role;
```

4 Task 4

4.1 Goal

This task implements Virtual Private Database policies for the Clinical Trial Management schema. The policies use `SYS_CONTEXT('USERENV', 'SESSION_USER')` to identify the connected Oracle user and dynamically restrict rows according to the assignments stored in `STUDY_ASSIGNMENTS`.

The SQL code is in:

- `app/4/00_cleanup_vpd_policies.sql`;
- `app/4/01_vpd_policy_functions.sql`;
- `app/4/02_add_vpd_policies.sql`;
- `app/4/03_grant_base_select_for_vpd.sql`;
- `app/4/04_check_vpd_policies.sql`.

4.2 VPD Policies

4.2.1 P1. Assigned studies only

Users can read only studies for which they have at least one assignment.

Target object:

- table: `CT_OWNER.STUDIES`;
- policy: `VPD_STUDIES_BY_ASSIGNMENT`;
- function: `CT_OWNER.VPD_STUDIES_BY_ASSIGNMENT`.

Returned predicate:

```
EXISTS (
  SELECT 1
  FROM (
    SELECT a.study_id AS assigned_study_id,
           sm.username AS assigned_username
    FROM ct_owner.study_assignments a
    JOIN ct_owner.staff_members sm
      ON sm.staff_id = a.staff_id
  ) user_assignment
  WHERE assigned_username = SYS_CONTEXT('USERENV', 'SESSION_USER')
    AND assigned_study_id = study_id
)
```

Cost:

- VPD functions: 1;
- VPD policies: 1;
- application context: no custom context, only USERENV;
- direct grants needed for testing: 7 users on STUDIES.

4.2.2 P2. Participants by assigned study and site

Coordinators can read participants only for their assigned study site. Study leaders, data managers and auditors can read participants for assigned studies even when their assignment is not tied to one site.

Target object:

- table: CT_OWNER.PARTICIPANTS;
- policy: VPD_PARTICIPANTS_BY_SITE;
- function: CT_OWNER.VPD_PARTICIPANTS_BY_SITE.

Returned predicate:

```
EXISTS (
  SELECT 1
  FROM (
    SELECT a.study_id AS assigned_study_id,
           a.site_id AS assigned_site_id,
           a.assignment_role AS assigned_role,
           sm.username AS assigned_username
    FROM ct_owner.study_assignments a
    JOIN ct_owner.staff_members sm
      ON sm.staff_id = a.staff_id
  ) user_assignment
  WHERE assigned_username = SYS_CONTEXT('USERENV', 'SESSION_USER')
    AND assigned_study_id = study_id
    AND (
      assigned_site_id = site_id
      OR assigned_site_id IS NULL
      OR assigned_role IN ('PI', 'DATA_MANAGER', 'AUDITOR')
    )
    AND assigned_role IN ('PI', 'COORDINATOR', 'DATA_MANAGER', 'AUDITOR
       ')
)
```

Cost:

- VPD functions: 1;
- VPD policies: 1;
- application context: USERENV.SESSION_USER;

- direct grants needed for testing: 4 users on `PARTICIPANTS`.

4.2.3 P3. Documents by assignment and document type

Users can read trial documents only when their assignment justifies access to the document's study, site and document type.

Target object:

- table: `CT_OWNER.TRIAL_DOCUMENTS`;
- policy: `VPD_DOCUMENTS_BY_ASSIGNMENT`;
- function: `CT_OWNER.VPD_DOCUMENTS_BY_ASSIGNMENT`.

Main restrictions:

- monitors see only `MONITORING_REPORT` documents for assigned sites;
- regulatory reviewers see `REGULATORY_SUBMISSION`, `PROTOCOL`, and `INFORMED_CONSENT` documents for assigned studies;
- sponsors see non-financial documents for assigned studies;
- principal investigators, data managers and auditors see documents for their assigned studies.

Cost:

- VPD functions: 1;
- VPD policies: 1;
- application context: `USERENV.SESSION_USER`;
- direct grants needed for testing: 7 users on `TRIAL_DOCUMENTS`.

4.2.4 P4. Safety events by assignment

Only principal investigators, data managers and auditors can read adverse event rows, and only for assigned studies.

Target object:

- table: `CT_OWNER.ADVERSE_EVENTS`;
- policy: `VPD_EVENTS_BY_ASSIGNMENT`;
- function: `CT_OWNER.VPD_EVENTS_BY_ASSIGNMENT`.

Returned predicate:

```sql
EXISTS (
  SELECT 1
  FROM (
    SELECT a.study_id AS assigned_study_id,
           a.assignment_role AS assigned_role,
           sm.username AS assigned_username
    FROM ct_owner.study_assignments a
    JOIN ct_owner.staff_members sm
      ON sm.staff_id = a.staff_id
  ) user_assignment
  WHERE assigned_username = SYS_CONTEXT('USERENV', 'SESSION_USER')
    AND assigned_study_id = study_id
    AND assigned_role IN ('PI', 'DATA_MANAGER', 'AUDITOR')
)
```

Cost:

- VPD functions: 1;
- VPD policies: 1;
- application context: `USERENV.SESSION_USER`;
- direct grants needed for testing: 3 users on `ADVERSE_EVENTS`.

4.3 Global Cost Analysis

The implementation enforces four VPD policies, which is more than half of the six high-level policies defined for Task 2.

Item	Count
VPD policy functions	4
`DBMS_RLS.ADD_POLICY` calls	4
Custom application contexts	0
USERENV attributes used	1
Base table grants for testing	21

The main advantage over DAC is that the number of views does not grow with the number of users or assignments. A single predicate function per table can serve all users because the predicate is generated from the connected user.

4.4 SQL Execution

Run the scripts in this order:

```
-- As CT_OWNER
@app/4/01_vpd_policy_functions.sql

-- As CT_OWNER, or ADMIN if DBMS_RLS is not executable by CT_OWNER
@app/4/00_cleanup_vpd_policies.sql
@app/4/02_add_vpd_policies.sql

-- As CT_OWNER
@app/4/03_grant_base_select_for_vpd.sql
@app/4/04_check_vpd_policies.sql
```

Then connect as application users and query base tables such as `CT_OWNER.PARTICIPANTS`, `CT_OWNER.TRIAL_DOCUMENTS`, or `CT_OWNER.ADVERSE_EVENTS`. Oracle rewrites each query by adding the predicate returned by the corresponding VPD function.

5 Task 5

5.1 Goal

This task implements the VPD policies from Task 4 using an Oracle application context. The context stores session-specific information about the connected clinical trial user, and the VPD policy functions read that context instead of joining `STAFF_MEMBERS` on every predicate.

The SQL code is in:

- `app/5/01_context_package.sql`;
- `app/5/02_create_context_and_logon_trigger.sql`;
- `app/5/03_context_vpd_functions.sql`;
- `app/5/04_replace_vpd_policies.sql`;
- `app/5/05_check_context_and_policies.sql`.

5.2 Application Context

The application context is named `CT_APP_CTX` and is associated with the package `CT_OWNER.SET_CT_CTX_PKG`.

The context contains five attributes, more than the minimum required for one student:

Attribute	Meaning
USERNAME	connected Oracle username
STAFF_ID	internal staff identifier from STAFF_MEMBERS
JOB_ROLE	business role
REGION	operational region
CLEARANCE	clearance level used by sensitive policies

The package procedure SET_CONTEXT reads the current user from:

```
SYS_CONTEXT('USERENV', 'SESSION_USER')
```

Then it retrieves the corresponding row from STAFF_MEMBERS and sets context attributes with DBMS_SESSION.SET_CONTEXT.

5.3 Initialization

The script 02_create_context_and_logon_trigger.sql creates:

```
CREATE OR REPLACE CONTEXT ct_app_ctx USING ct_owner.set_ct_ctx_pkg;
```

It also creates an AFTER LOGON ON DATABASE trigger. For every CT_% user, the trigger calls:

```
ct_owner.set_ct_ctx_pkg.set_context;
```

If the trigger cannot be created in the Autonomous Database environment, the same procedure can be called manually after login for testing.

5.4 Context-Based VPD Policies

5.4.1 P1. Assigned studies only

Target:

- table: CT_OWNER.STUDIES;
- policy: VPD_STUDIES_BY_ASSIGNMENT;
- function: CTX_VPD_STUDIES_BY_ASSIGNMENT.

Returned predicate:

```
EXISTS (
  SELECT 1
  FROM ct_owner.study_assignments a
  WHERE a.staff_id = TO_NUMBER(SYS_CONTEXT('CT_APP_CTX', 'STAFF_ID'))
    AND a.study_id = study_id
)
```

The predicate uses the context attribute `STAFF_ID`.

5.4.2 P2. Participants by assigned study and site

Target:

- table: `CT_OWNER.PARTICIPANTS`;
- policy: `VPD_PARTICIPANTS_BY_SITE`;
- function: `CTX_VPD_PARTICIPANTS_BY_SITE`.

The policy uses:

- `STAFF_ID` to match the current user's assignments;
- `JOB_ROLE` to allow global study access for principal investigators, data managers and auditors.

5.4.3 P3. Documents by assignment and document type

Target:

- table: `CT_OWNER.TRIAL_DOCUMENTS`;
- policy: `VPD_DOCUMENTS_BY_ASSIGNMENT`;
- function: `CTX_VPD_DOCUMENTS_BY_ASSIGNMENT`.

The policy uses:

- `STAFF_ID` to restrict documents to assigned studies;
- `JOB_ROLE` to distinguish site-level users from study-level roles;
- assignment role and document type to enforce the document access rules.

Examples:

- monitors see only `MONITORING_REPORT`;
- regulatory officers see regulatory submissions, protocols and consent forms;
- sponsors see non-financial documents.

5.4.4 P4. Safety events by assignment and clearance

Target:

- table: CT_OWNER.ADVERSE_EVENTS;
- policy: VPD_EVENTS_BY_ASSIGNMENT;
- function: CTX_VPD_EVENTS_BY_ASSIGNMENT.

Returned predicate:

```
EXISTS (
  SELECT 1
  FROM ct_owner.study_assignments a
  WHERE a.staff_id = TO_NUMBER(SYS_CONTEXT('CT_APP_CTX', 'STAFF_ID'))
    AND a.study_id = study_id
    AND a.assignment_role IN ('PI', 'DATA_MANAGER', 'AUDITOR')
    AND SYS_CONTEXT('CT_APP_CTX', 'CLEARANCE') = 'RESTRICTED'
)
```

This policy uses both STAFF_ID and CLEARANCE.

5.5 Cost Analysis

Item	Count
Application contexts	1
Context attributes	5
Context package specifications	1
Context package bodies	1
Logon triggers	1
Context-based VPD functions	4
DBMS_RLS.ADD_POLICY calls	4

Compared with Task 4, the number of VPD policies is unchanged. The benefit is that user metadata is loaded once into session memory and can be reused by all policy functions.

5.6 SQL Execution

Run the scripts in this order:

```
-- As CT_OWNER
@app/5/01_context_package.sql

-- As ADMIN
@app/5/02_create_context_and_logon_trigger.sql

-- As CT_OWNER
@app/5/03_context_vpd_functions.sql

-- As CT_OWNER, or ADMIN if DBMS_RLS is not executable by CT_OWNER
@app/5/04_replace_vpd_policies.sql

-- As ADMIN or CT_OWNER, depending on dictionary privileges
@app/5/05_check_context_and_policies.sql
```

For manual testing after connecting as an application user:

```
BEGIN
  ct_owner.set_ct_ctx_pkg.set_context;
END;
/

SELECT SYS_CONTEXT('CT_APP_CTX', 'STAFF_ID') FROM dual;
SELECT * FROM ct_owner.trial_documents;
```

6 Task 6

6.1 Goal

This task implements Oracle Label Security policies for the Clinical Trial Management schema. The OLS model protects sensitive rows using labels composed of both:

- a **level**, representing sensitivity;
- a **compartment**, representing the information domain.

The SQL code is in:

- `app/6/00_create_ols_policy.sql`;
- `app/6/01_create_label_components.sql`;
- `app/6/02_authorize_ols_users.sql`;
- `app/6/03_apply_ols_to_tables.sql`;
- `app/6/04_label_table_rows.sql`;
- `app/6/05_grant_and_check_ols.sql`.

6.2 High-Level OLS Policies

6.2.1 OLS-P1. Clinical and personal data protection

Clinical study records and participant records are labeled with the `CLIN` compartment. Participant data can be `CONFIDENTIAL` or `RESTRICTED`.

Users can read a row only when their OLS session label dominates the row label:

- the user level is greater than or equal to the row level;
- the user has the `CLIN` compartment.

This protects:

- `STUDIES`;
- `PARTICIPANTS`;
- clinical documents in `TRIAL_DOCUMENTS`.

6.2.2 OLS-P2. Regulated, financial and safety material separation

Regulatory submissions, financial contracts and safety reports are separated with compartments:

- `REG` for regulatory documents;
- `FIN` for financial contracts;
- `SAFE` for safety reports and adverse events.

Examples:

- `CT_REG_BLU` can read `REG` material up to `RESTRICTED`;
- `CT_SPONSOR_LILA` can read `CLIN` and `REG` material only up to `CONFIDENTIAL`;
- `CT_AUDITOR_GIALLI` can read all compartments up to `RESTRICTED`;
- users without `FIN` cannot read financial contract rows.

6.3 OLS Policy

The OLS policy is:

Property	Value
Policy name	`CT_OLS_POL`
Label column	`OLS_LABEL`

Property	Value
Default option	READ_CONTROL

READ_CONTROL means that row visibility is controlled for read operations.

6.4 Label Components

6.4.1 Levels

Level number	Short name	Long name
1000	P	PUBLIC
2000	I	INTERNAL
3000	C	CONFIDENTIAL
4000	R	RESTRICTED

6.4.2 Compartments

Compartment number	Short name	Long name
10	CLIN	CLINICAL
20	REG	REGULATORY
30	FIN	FINANCIAL
40	SAFE	SAFETY

6.5 Data Labels

Label tag	Label value	Meaning
1010	P:CLIN	public clinical information
2010	I:CLIN	internal clinical information

Label tag	Label value	Meaning
3010	C:CLIN	confidential clinical information
4010	R:CLIN	restricted clinical or personal data
3020	C:REG	confidential regulatory material
4020	R:REG	restricted regulatory material
4030	R:FIN	restricted financial material
3040	C:SAFE	confidential safety material
4040	R:SAFE	restricted safety material

6.6 User Labels

User	Max level	Compartments
CT_PI_ROSSI	R	CLIN,REG,SAFE
CT_COORD_BIANCHI	C	CLIN
CT_CRA_VERDI	C	CLIN,SAFE
CT_DATA_NERI	R	CLIN,SAFE
CT_REG_BLU	R	REG,CLIN
CT_AUDITOR_GIALLI	R	CLIN,REG,FIN,SAFE
CT_SPONSOR_LILA	C	CLIN,REG

`CT_OWNER` receives the OLS `FULL` privilege so it can assign row labels.

6.7 Protected Tables

The policy is applied to:

- `CT_OWNER.STUDIES`;
- `CT_OWNER.PARTICIPANTS`;
- `CT_OWNER.TRIAL_DOCUMENTS`;
- `CT_OWNER.ADVERSE_EVENTS`.

Rows are labeled from existing classification columns:

- `STUDIES.SENSITIVITY_LABEL`;
- `PARTICIPANTS.PERSONAL_DATA_LABEL`;
- `TRIAL_DOCUMENTS.CLASSIFICATION` and `TRIAL_DOCUMENTS.DOCUMENT_TYPE`;
- `ADVERSE_EVENTS.SAFETY_LABEL`.

6.8 Cost Analysis

Item	Count
OLS policies	1
Protected tables	4
Levels	4
Compartments	4
Data labels	9
User label authorizations	7
High-level OLS policies	2

The policy uses one label column per protected table and avoids creating separate views for every label combination. Access is controlled by label dominance between the user session label and the row label.

6.9 SQL Execution

Run the scripts in this order:

```
-- As LBACSYS or an OLS administrator
@app/6/00_create_ols_policy.sql

-- As a user with CT_OLS_POL_DBA enabled
@app/6/01_create_label_components.sql
@app/6/02_authorize_ols_users.sql
@app/6/03_apply_ols_to_tables.sql

-- As CT_OWNER
@app/6/04_label_table_rows.sql
@app/6/05_grant_and_check_ols.sql
```

Example checks:

```sql
-- Regulatory officer: should see REG material but not FIN rows
CONNECT ct_reg_blu/"LabTask1_2026#"
SELECT document_id, document_type, classification
FROM ct_owner.trial_documents;

-- Auditor: should see FIN and SAFE rows up to RESTRICTED
CONNECT ct_auditor_gialli/"LabTask1_2026#"
SELECT document_id, document_type, classification
FROM ct_owner.trial_documents;
SELECT event_id, severity, safety_label
FROM ct_owner.adverse_events;
```